

Checklist

Databases

1. Database Architecture

- ☐ Understand where the organization's critical and sensitive data is stored.
- ☐ Know which database technologies are in use:
 - ☐ Relational databases such as MySQL, PostgreSQL, and SQL Server
 - ☐ NoSQL databases such as MongoDB
 - ☐ Cloud-managed databases
 - ☐ Serverless databases
 - ☐ Self-managed/on-premises databases
- ☐ Understand which databases are business-critical.
- ☐ Know who owns and operates each database.
- ☐ Understand the security implications of on-premises versus cloud-hosted databases.
- ☐ Understand the **shared responsibility model** for cloud databases.

2. Data Classification

- ☐ Know what sensitive information the organization stores.
- ☐ Ensure data is classified according to sensitivity.
- ☐ Identify databases containing:
 - ☐ Customer information
 - ☐ Personal information
 - ☐ Financial information
 - ☐ Authentication credentials
 - ☐ Intellectual property
 - ☐ Operationally critical information
- ☐ Ensure the highest-risk databases receive the strongest protection.

3. Access Control

- ☐ Understand the difference between **authentication** and **authorization**.
- ☐ Ensure database access follows the **principle of least privilege**.
- ☐ Confirm users and applications receive only the permissions they require.
- ☐ Ensure administrative privileges are tightly restricted.
- ☐ Understand how privileged database accounts are managed.
- ☐ Ensure former employees and unnecessary accounts are removed promptly.
- ☐ Require strong authentication for privileged access.
- ☐ Ensure service accounts and application credentials are securely managed.
- ☐ Avoid shared administrator accounts wherever possible.

4. Privileged Access Management

- ☐ Know who has administrative or elevated database privileges.
- ☐ Ensure privileged access is logged and monitored.
- ☐ Consider a **Privileged Access Management (PAM)** solution for critical systems.
- ☐ Require periodic review of privileged accounts.
- ☐ Verify that application accounts do not have unnecessary administrator or system-level privileges.

5. Encryption

- ☐ Ensure sensitive database information is encrypted **at rest**.
- ☐ Ensure sensitive database traffic is encrypted **in transit** using TLS.
- ☐ Understand technologies such as **Transparent Data Encryption (TDE)**.
- ☐ Ensure database backups are encrypted.
- ☐ Ensure encryption keys are stored separately from the encrypted data.
- ☐ Ensure encryption keys are rotated and access to them is controlled.
- ☐ Understand who owns and manages encryption keys.
- ☐ Ensure a secure key-management or secrets-management solution is used.

6. Passwords and Secrets

- ☐ Ensure passwords are never stored in plaintext.
- ☐ Understand the difference between **hashing** and **encryption**.
- ☐ Ensure passwords are protected using appropriate password-hashing algorithms.
- ☐ Ensure salts are used for password hashing.

- ☐ Ensure database passwords, API keys, connection strings, and secrets are not hard-coded in application source code.
- ☐ Use a centralized **secrets manager** where appropriate.
- ☐ Ensure secrets can be rotated without major operational disruption.

7. SQL Injection

- ☐ Understand what **SQL injection** is and why it remains a major application/database risk.
- ☐ Ensure applications use parameterized queries or equivalent secure development techniques.
- ☐ Ensure user input is properly validated.
- ☐ Verify application database accounts follow least privilege.
- ☐ Understand that SQL injection becomes significantly more dangerous when the application has excessive database privileges.
- ☐ Ensure secure coding practices are included in development standards.
- ☐ Ensure SQL injection is covered by application security testing.

8. Unauthorized Access

- ☐ Understand the risks from:
 - ☐ Brute-force attacks
 - ☐ Credential stuffing
 - ☐ Password reuse
 - ☐ Dictionary attacks
 - ☐ Stolen credentials
- ☐ Require strong password and authentication policies.
- ☐ Use MFA where appropriate, especially for administrative access.
- ☐ Implement account lockout or rate-limiting controls where appropriate.
- ☐ Monitor repeated or abnormal authentication failures.
- ☐ Ensure default credentials and unnecessary default accounts are removed.

9. Insider Threats

- ☐ Recognize that legitimate users can also create database-security risks.
- ☐ Understand the difference between:
 - ☐ Malicious insiders
 - ☐ Accidental/inadvertent insider threats

- ☐ Restrict access based on job responsibilities.
- ☐ Monitor privileged-user activity.
- ☐ Maintain separation of duties for sensitive administrative operations.
- ☐ Ensure sensitive information cannot be copied or exported without appropriate controls.
- ☐ Review access when employees change roles.

10. Data Leakage and Exfiltration

- ☐ Understand how database information could leave the organization.
- ☐ Ensure databases are not unnecessarily exposed to the public internet.
- ☐ Protect database communications from interception.
- ☐ Secure backups, exports, snapshots, and replicas.
- ☐ Restrict the use of production data in development and testing environments.
- ☐ Monitor unusual bulk downloads or database queries.
- ☐ Implement controls to identify possible data exfiltration.
- ☐ Understand how cloud misconfigurations can expose databases.

11. Secure Configuration and Hardening

- ☐ Ensure databases follow documented security-hardening standards.
- ☐ Apply the **principle of least functionality**.
- ☐ Disable unnecessary database services and features.
- ☐ Remove insecure default configurations.
- ☐ Restrict network connectivity to required systems only.
- ☐ Use firewalls and network segmentation.
- ☐ Consider recognized standards such as:
 - ☐ CIS Benchmarks
 - ☐ DISA STIGs
- ☐ Require regular configuration reviews.

12. Vulnerability and Patch Management

- ☐ Know which database platforms and versions are running.
- ☐ Ensure unsupported database versions are identified and replaced.
- ☐ Establish a process for database security updates.
- ☐ Define how quickly critical vulnerabilities must be patched.
- ☐ Understand exceptions where patches cannot immediately be deployed.

- ☐ Require compensating controls when patching is delayed.
- ☐ Track critical database vulnerabilities through remediation.

13. Logging, Monitoring, and Detection

- ☐ Ensure important database activity is logged.
- ☐ Monitor successful and failed authentication attempts.
- ☐ Monitor privileged administrative actions.
- ☐ Monitor changes to permissions and security configurations.
- ☐ Monitor unusual database queries or unusually large data transfers.
- ☐ Forward relevant logs to centralized monitoring such as a SIEM/XDR platform.
- ☐ Define alerts for suspicious database behavior.
- ☐ Ensure logs are retained long enough to support investigations.
- ☐ Verify that someone is responsible for reviewing and responding to alerts.

14. Backup and Recovery

- ☐ Ensure critical databases are backed up regularly.
- ☐ Ensure backups are encrypted.
- ☐ Restrict access to backup files and snapshots.
- ☐ Maintain copies that cannot easily be modified or deleted by an attacker.
- ☐ Define database Recovery Time Objectives (**RTO**).
- ☐ Define Recovery Point Objectives (**RPO**).
- ☐ Test database restoration regularly.
- ☐ Confirm recovery procedures work before an incident occurs.

15. Availability and Resilience

- ☐ Understand which databases are essential to business operations.
- ☐ Ensure critical databases have appropriate redundancy.
- ☐ Understand database failover capabilities.
- ☐ Plan for hardware, software, network, and cloud-provider failures.
- ☐ Understand dependencies between databases and critical applications.
- ☐ Include databases in disaster-recovery and business-continuity planning.

16. Cloud Database Security

- ☐ Know which databases are hosted in AWS, Azure, Google Cloud, or other providers.
- ☐ Understand which security responsibilities belong to the provider and which belong to the organization.
- ☐ Review cloud IAM permissions regularly.
- ☐ Avoid unnecessary public database endpoints.
- ☐ Restrict database access through network security controls.
- ☐ Enable encryption, logging, backups, and monitoring.
- ☐ Ensure cloud database configurations are continuously reviewed for misconfiguration.

17. Database Security Governance

- ☐ Assign clear ownership for each critical database.
- ☐ Establish documented database-security standards.
- ☐ Define minimum requirements for:
 - ☐ Access control
 - ☐ Authentication
 - ☐ Encryption
 - ☐ Logging
 - ☐ Backups
 - ☐ Network security
 - ☐ Patching
 - ☐ Vulnerability management
- ☐ Require periodic database-security reviews.
- ☐ Ensure exceptions are documented and approved.
- ☐ Track unresolved database risks at the appropriate management level.

18. Incident Response

- ☐ Ensure database breaches are included in the incident-response plan.
- ☐ Know who must be involved if sensitive database information is compromised.
- ☐ Ensure the organization can determine:
 - ☐ What data was accessed
 - ☐ Who accessed it
 - ☐ When the access occurred
 - ☐ How much data was taken
 - ☐ Which credentials were compromised

- ☐ Maintain sufficient logging to support investigations.
- ☐ Understand regulatory and customer-notification obligations.
- ☐ Include database compromise scenarios in incident-response exercises.

19. Third Parties, Acquisitions, and Legacy Systems

- ☐ Assess database security when acquiring another company.
- ☐ Do not assume inherited systems meet the organization's security standards.
- ☐ Identify unsupported or legacy databases.
- ☐ Review third-party access to sensitive databases.
- ☐ Understand how vendors protect company data.
- ☐ Include database-security requirements in supplier and outsourcing agreements.
- ☐ Plan remediation of inherited security weaknesses after mergers or acquisitions.

20. Questions You Should Be Able to Answer

- ☐ What are our most critical databases?
- ☐ What sensitive data do they contain?
- ☐ Who can access them?
- ☐ Who has administrator privileges?
- ☐ Are those privileges actually necessary?
- ☐ Are sensitive data and backups encrypted?
- ☐ Where are the encryption keys stored?
- ☐ Are any databases publicly accessible?
- ☐ How are database credentials and secrets managed?
- ☐ How quickly do we patch critical database vulnerabilities?
- ☐ How would we detect unauthorized database access?
- ☐ Would we detect someone exporting millions of records?
- ☐ Can we identify exactly what an administrator did?
- ☐ When did we last successfully restore a critical database from backup?
- ☐ How quickly could we recover a critical database?
- ☐ Do our cloud databases follow the same security requirements as our on-premises databases?
- ☐ What are our three largest unresolved database-security risks?

Priority Reminder

- ☐ **What data do we have, and where is it?**
- ☐ **Who can access it, and why?**
- ☐ **How is it protected?**
- ☐ **How would we detect misuse or compromise?**
- ☐ **Can we recover quickly if something goes wrong?**

If these five questions cannot be answered clearly for every critical database, the organization has a database-security governance gap.